

Operationalising Zero-Knowledge

Privacy Classification of HTTP Metadata



PAYLOAD
(Encrypted)

**THE
VULNERABILITY**



METADATA
(Exposed)

Protecting the
'Full Compromise = Zero Impact' Promise

The Paradox of SGraph Send

We encrypt files, but the transfer leaves fingerprints.

Operational Necessity

- ⚙ Rate Limiting
- ⚙ Abuse Detection
- ⚙ Basic Analytics
- ⚙ Input: 14 distinct data points per request

Brand Promise

- 🛡 Privacy First Ethos
- 🛡 Zero-Knowledge Pledge
- 🛡 Risk: Storing operational data violates the brand

GOAL: A storage architecture where the server dataset remains non-sensitive, even in a total breach.

The Raw Feed: Inventory of Digital Exhaust

Source: Request Headers & CloudFront Metadata

NETWORK IDENTITY

-  IP Address (X-Forwarded-For)
-  ASN (Autonomous System Number)
-  ISP Name

DEVICE FINGERPRINT

-  User-Agent (Browser/OS)
-  TLS Cipher Suite
-  Screen Resolution

GEOLOCATION

-  Country (ISO Code)
-  Region / State
-  City
-  Coordinates (Lat/Long)

Insight: Every request carries a digital exhaust.

The Verdict: Is an IP Address PII?

YES.

Legal Citation: Breyer v Germany (Case C-582/14, CJEU)

Reasoning: Dynamic IP addresses constitute 'personal data' under GDPR Article 4(1) because the ISP holds the data **required to link** the IP to a specific subscriber.

IMPLICATION: We cannot store raw IP addresses. They are toxic assets that bring the entire database under full GDPR scope.

Crossing the Anonymisation Boundary



Insight: Effective anonymisation requires both technical measures (salting) and process controls (key deletion).

The Geolocation Gradient & K-Anonymity

Rule: Stored location must describe a population large enough to prevent identification.



Country/Region (UK)

Safe. Describes millions.

City (London)

Borderline. Safe for large cities.

Zip/Lat-Long

Unsafe. Describes specific households.

Policy: We stop at the City level. Granular data is discarded immediately.

The User-Agent Trap

Threat: Browser Fingerprinting (ref: EFF Panopticklick)

! Mozilla/5.0
(Macintosh; Intel
Mac OS X 10_15_7)
AppleWebKit/537.36
(KHTML, like Gecko)
Chrome/114.0.0.0
Safari/537.36

Specific UA + Timezone
= Unique ID



NORMALISATION

✓
Chrome/
macOS

Safe Analytics Value

The Three-Tier Storage Strategy

TIER 1

PLAINTEXT



Description:

Non-sensitive data. Safe to expose.

Examples:

ASN, Country, Timestamp

TIER 2

HASHED & SALTED



Description:

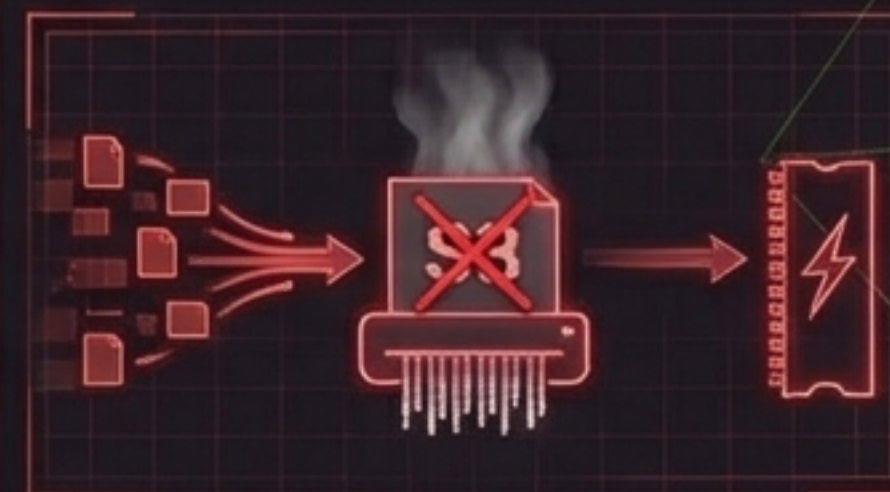
Unique IDs for abuse detection but toxic in plaintext.

Examples:

IP Address

TIER 3

EPHEMERAL / DISCARD



Description:

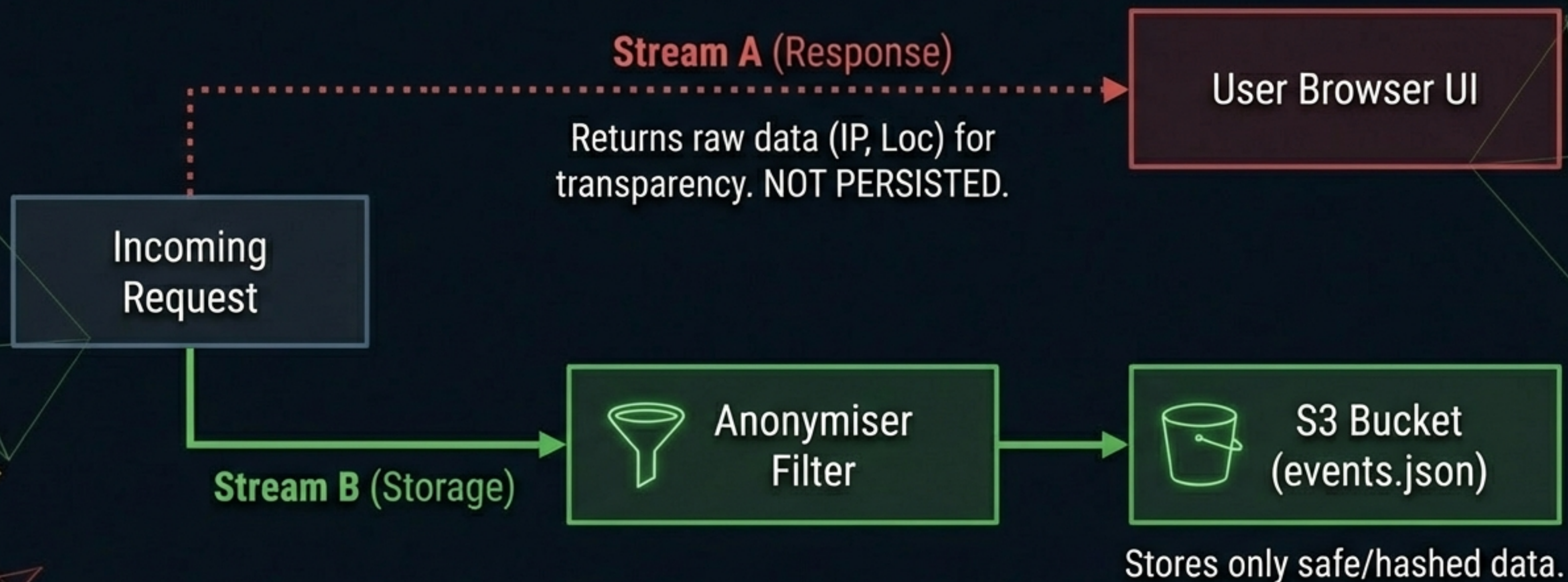
Used for live processing only. Never written to S3.

Examples:

Zip codes, Raw User-Agent

The UX Tension: Transparency vs. Privacy

Solution: Show Live, Store Safe.



No regulatory requirement to store data just because we displayed it.

Recommendation Matrix: Network & Identity

FIELD	CLASSIFICATION	ACTION	FORMAT STORED
IP Address	PII	Anonymise	SHA-256(IP + Salt)
ASN (Autonomous System)	Non-Personal	Store	Plaintext (e.g., 'AS1234')
Connection Type	Non-Personal	Store	Plaintext (e.g., 'Residential')
ISP Name	Quasi-Identifier	Store	Plaintext

Recommendation Matrix: Geolocation

FIELD	CLASSIFICATION	ACTION	FORMAT STORED
Country	Non-Personal	Store	Plaintext (ISO Code)
Region / State	Non-Personal	Store	Plaintext
City	Quasi-Identifier	Store	Plaintext (High-level only)
Zip / Postal Code	PII (High Risk)	DISCARD	NULL
Latitude / Longitude	PII (High Risk)	DISCARD	NULL

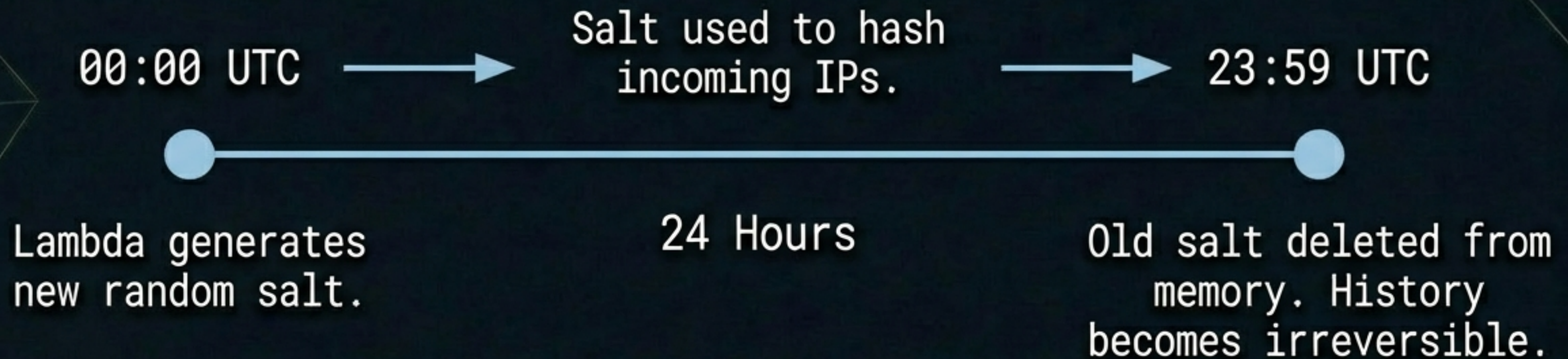
Recommendation Matrix: Device & Headers

FIELD	CLASSIFICATION	ACTION	FORMAT STORED
User-Agent	Quasi-Identifier	Normalise	'Family / OS' only
Referer Header	PII (URL Leak)	DISCARD	NULL
TLS Version / Cipher	Non-Personal	Store	Plaintext
Timestamp	Non-Personal	Store	ISO 8601 UTC

Technical Implementation: The Rolling Salt

Ensuring the database cannot be reversed.

$$\text{Hash} = \text{SHA-256}(\text{Raw_Value} + \text{Daily_Salt_Key})$$



Compliance & Threat Model Validation

✓ Regulatory Check

- ✓ GDPR / UK GDPR: COMPLIANT (Minimisation & Anonymisation)
- ✓ CCPA: COMPLIANT

✓ S3 Breach Scenario Analysis



- Attacker Gains: Hashed IPs, Generic Locations.
 - Attacker Lacks: The deleted salts.
- ✓ Impact: ZERO PII LEAKAGE.

Execution Plan

☑ Immediate Actions

- ✓ Infrastructure: Deploy Lambda for Salt Rotation Service.
- ✓ Configuration: Update IP Enrichment to drop Coordinates/Zip before logging.
- ✓ Legal: Update Privacy Policy to state 'Aggregated/Anonymised storage only'.

*“Privacy is not just a compliance checklist.
It is our product’s primary feature.”*